

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG

KHOA ĐA PHƯƠNG TIỆN



AN TOÀN THÔNG TIN

ĐỀ TÀI:

**NÊU CƠ CHẾ TẤN CÔNG, CÁCH PHÁT HIỆN ARP-POISONING
VÀ XÂY DỰNG CHƯƠNG PHÁT HIỆN ARP-POISONING**

Giảng viên: Hoàng Đăng Hải

Nhóm sinh viên: 8

Vũ Viết Duy B21DCPT089

Trần Tuấn Linh B21DCPT145

Trần Xuân Lâm B21DCPT138

Mai Thành Đạt B21DCPT072

Hà Nội – 2024

MỤC LỤC

CHƯƠNG I: GIỚI THIỆU	2
1.1. Giao thức ARP là gì	2
1.1.1. Khái niệm.....	2
1.1.2. Phân loại ARP	2
1.2 ARP- Poisoning là gì?.....	3
1.4 Mục đích của tấn công ARP-Poisoning	3
1.5 Tác động của các cuộc tấn công ARP-Poisoning	4
CHƯƠNG II: CƠ SỞ LÝ THUYẾT	5
2.1. Cơ chế tấn công ARP	5
2.2. Các phương pháp phát hiện cuộc tấn công ARP-Poisoning	6
2.2.1. Dấu hiệu của một cuộc tấn công đang diễn ra.....	6
2.2.2. Kỹ thuật phát hiện thụ động.....	7
2.2.3. Kỹ thuật phát hiện chủ động.....	8
2.2.4. Sử dụng công cụ dòng lệnh và phần mềm giám sát mạng	8
2.3. Cách bảo vệ hệ thống khỏi cuộc tấn công ARP-Poisoning	9
2.4. Các loại tấn công ARP-Poisoning.....	9
CHƯƠNG III: XÂY DỰNG CHƯƠNG TRÌNH PHÁT HIỆN ARP POISONING BẰNG PYTHON (SCAPY)	10
3.1. Giới thiệu về thư viện Scapy: Cách cài đặt và các chức năng liên quan đến ARP..	11
3.2. Cấu trúc của chương trình.....	12
3.2.1. Ý tưởng	12
3.2.2. Cài đặt chương trình	13
3.3. Mô tả tệp mẫu arp-poisoning.pcap.....	14
3.4. Kết quả thu được khi chạy chương trình.....	15
CHƯƠNG IV: HƯỚNG PHÁT TRIỂN.....	16
4.1. Tổng kết	16
4.2. Hướng phát triển mở rộng.....	16
CHƯƠNG V. PHÂN CÔNG NHÓM	17

CHƯƠNG I: GIỚI THIỆU

1.1. Giao thức ARP là gì

1.1.1. Khái niệm

ARP là viết tắt của Address Resolution Protocol, là một giao thức mạng được dùng để tìm ra địa chỉ phần cứng (địa chỉ MAC) của thiết bị từ một địa chỉ IP nguồn. Nó được sử dụng khi một thiết bị giao tiếp với các thiết bị khác dựa trên nền tảng local network.

Mục đích của ARP là giúp các thiết bị trong cùng mạng nội bộ (LAN) có thể nhận biết và trao đổi dữ liệu với nhau một cách hiệu quả. Cách thức hoạt động của ARP là dựa trên quá trình request và response giữa các thiết bị. Khi một thiết bị muốn gửi dữ liệu cho một thiết bị khác trong cùng mạng, nó sẽ gửi một bản tin ARP request chứa địa chỉ IP đích lên toàn mạng.

Địa chỉ MAC (Media Access Control) là một địa chỉ duy nhất được gán cho mỗi thiết bị kết nối vào mạng. Đây là một địa chỉ vật lý được gắn trực tiếp vào phần cứng của thiết bị. Địa chỉ MAC bao gồm 6 octet, mỗi octet được biểu diễn bằng 2 ký tự hexa

VD: 48-E7-DA-44-81-1D

Cách thức hoạt động của ARP là dựa trên quá trình request và response giữa các thiết bị. Khi một thiết bị muốn gửi dữ liệu cho một thiết bị khác trong cùng mạng, nó sẽ gửi một bản tin ARP request chứa địa chỉ IP đích lên toàn mạng. Thiết bị có địa chỉ IP đích sẽ phản hồi lại với một bản tin ARP response chứa địa chỉ MAC của nó. Sau đó, thiết bị gửi sẽ lưu lại thông tin này vào bảng ARP cache để sử dụng cho các lần gửi sau.

1.1.2. Phân loại ARP

ARP cơ bản (Basic ARP): Loại ARP basic được sử dụng phổ biến nhất, dùng để phân giải địa chỉ IP sang địa chỉ MAC trong cùng một mạng nội bộ. Quá trình hoạt động của ARP cơ bản gồm hai bước: gửi yêu cầu ARP (ARP request) và nhận phản hồi ARP (ARP reply)

Proxy ARP: Nhằm hỗ trợ các thiết bị trong mạng con khác nhau giao tiếp với nhau thông qua một router. Router sẽ đóng vai trò là proxy, tức là đại diện cho các thiết bị khác trong việc trả lời yêu cầu ARP.

Gratuitous ARP: Là loại ARP dùng để thông báo cho các thiết bị trong mạng biết về sự thay đổi địa chỉ IP hoặc MAC của một thiết bị nào đó. Thiết bị sẽ gửi một yêu cầu ARP cho chính nó, và nếu có thiết bị nào có cùng địa chỉ IP hoặc MAC, nó sẽ phản hồi lại.

Reverse ARP: Dùng để tìm ra địa chỉ IP của thiết bị từ địa chỉ MAC. Nó được sử dụng khi một thiết bị chưa được cấp địa chỉ IP từ DHCP hoặc BOOTP, và muốn biết địa chỉ IP của chính nó.

Inverse ARP: Với Inverse người dùng sẽ tìm ra địa chỉ IP của thiết bị từ địa chỉ MAC trong các mạng không dây hoặc Frame Relay. Nó được sử dụng khi một thiết bị muốn biết địa chỉ IP của các thiết bị khác mà nó đã kết nối.

1.2 ARP- Poisoning là gì?

ARP spoofing, còn được gọi là ARP poisoning, là một cuộc tấn công Man in the Middle (MitM) cho phép kẻ tấn công chặn giao tiếp giữa các thiết bị mạng.

ARP spoofing đánh lừa địa chỉ MAC giả mạo là chính xác cho cả hai địa chỉ IP của bộ định tuyến và máy trạm nhằm mục đích kết nối trực tiếp với thiết bị của kẻ tấn công. Đồng thời hai thiết bị cập nhật bộ nhớ đệm ARP cũng sẽ trực tiếp kết nối với kẻ tấn công.

1.4 Mục đích của tấn công ARP-Poisoning

Mục đích cơ bản của một cuộc tấn công ARP-Poisoning là chặn, thao túng hoặc phá vỡ lưu lượng mạng giữa các thiết bị. Kẻ tấn công có thể thực hiện nhiều hành động như

- Nghe lén : Khi kẻ tấn công khởi chạy một cuộc tấn công ARP Spoofing, chúng chặn các gói dữ liệu đi qua mạng. Sau đó, chúng có thể truy cập một cách bí mật vào thông tin nhạy cảm như thông tin đăng nhập, dữ liệu tài chính và thông tin liên lạc cá nhân. Đây là hình thức nghe lén nguy hiểm nhất khi dữ liệu riêng tư có thể dễ dàng bị truy cập và khai thác bằng mạng không được mã hóa.

- Sửa đổi dữ liệu : ARP spoofing không chỉ là việc chặn dữ liệu đơn giản; trên thực tế, nó thay đổi nội dung của các gói dữ liệu trong khi vẫn đang truyền. Điều này bao gồm thay đổi tin nhắn, đưa mã độc vào các gói dữ liệu, cũng như làm hỏng các tệp. Ví dụ, kẻ tấn công có thể thay đổi các giao dịch tài chính hoặc sửa đổi thông tin quan trọng trong giao tiếp và điều này có thể làm hỏng tính toàn vẹn của dữ liệu và niềm tin của người dùng hoặc hệ thống.
- Từ chối dịch vụ (DoS) : Mô-đun này cũng có thể được sử dụng như một cuộc tấn công DoS để kích hoạt sự gián đoạn của các hoạt động mạng bình thường. Việc giả mạo các phản hồi ARP có thể làm ngập các thiết bị cụ thể trên mạng hoặc chuyển hướng lưu lượng đến các đích không xác định hoặc đến các đích sai.

1.5 Tác động của các cuộc tấn công ARP-Poisoning

Tác động của ARP spoofing nghiêm trọng hơn nhiều so với chỉ là sự gián đoạn đơn thuần và có thể gây ra mối đe dọa nghiêm trọng cho các cá nhân và tổ chức nói chung. Thiệt hại phát sinh từ hoạt động như vậy, bao gồm cả việc đánh cắp dữ liệu, mất kết nối hoặc các hình thức mất mát khác, rất khó để khôi phục hoàn toàn sau khi chúng đã xảy ra.

- Trộm cắp dữ liệu: Kẻ tấn công có thể đánh cắp mật khẩu và thông tin đăng nhập khác, bằng tin nhắn riêng tư và thông tin tài chính khác. Điều này rất nguy hiểm khi các mạng như vậy không được mã hóa. Trong trường hợp này, vi phạm sẽ tiết lộ dữ liệu bí mật hoặc độc quyền và gây ra thiệt hại về mặt pháp lý và danh tiếng cho doanh nghiệp
- Gián đoạn mạng: Các cuộc tấn công mạng độc hại bao gồm làm hỏng bảng ARP hoặc định tuyến lại/chặn lưu lượng làm chậm quy trình và dẫn đến tình trạng ngừng hoạt động, cùng với các cuộc tấn công từ chối dịch vụ, dẫn đến một số thời gian ngừng hoạt động liên quan đến kinh doanh cũng như mất năng suất và có thể gián đoạn dịch vụ.

- Phân phối phần mềm độc hại: Kẻ tấn công có thể đưa mã độc vào lưu lượng bị chặn, dẫn đến nhiễm phần mềm độc hại trong mạng. Nó có thể gây ra tình trạng nhiễm trùng rộng rãi, làm hỏng dữ liệu và vi phạm bảo mật hơn nữa

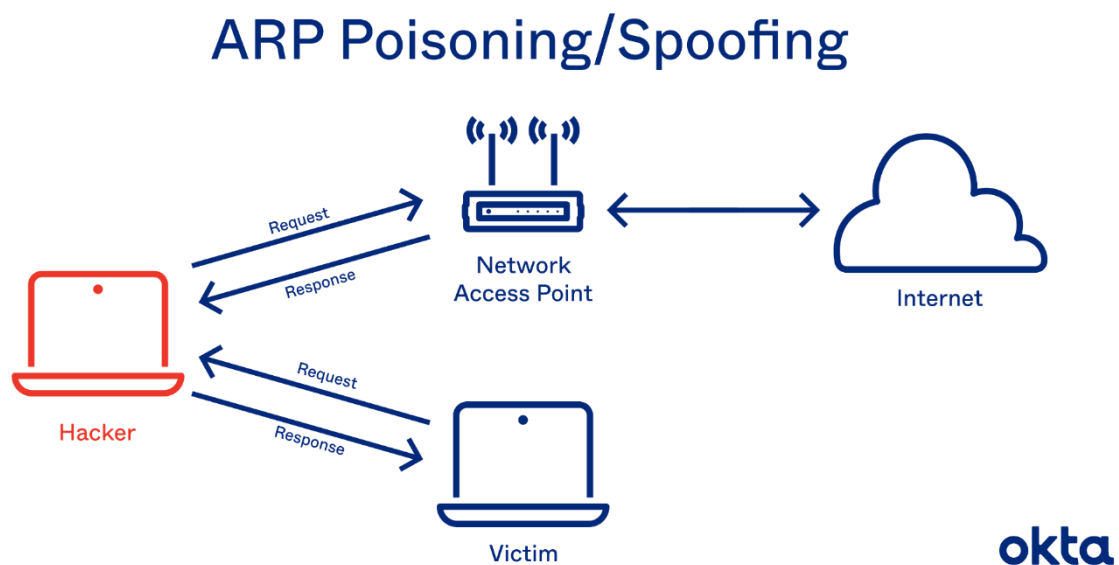
CHƯƠNG II: CƠ SỞ LÝ THUYẾT

2.1. Cơ chế tấn công ARP

Kẻ tấn công sử dụng ARP spoofing thường có xu hướng thực hiện theo một trình tự các bước để thực hiện cuộc tấn công hiệu quả

- **Quét:** Bước đầu tiên của một cuộc tấn công giả mạo ARP là quét mạng để tìm địa chỉ IP mục tiêu. Quá trình quét bắt đầu bằng việc kẻ tấn công sử dụng các công cụ cơ sở hạ tầng mạng để tìm ra các thiết bị đang hoạt động và địa chỉ IP của chúng. Vì vậy, giai đoạn quét hữu ích cho kẻ tấn công trong việc thu thập thông tin hữu ích liên quan đến cấu trúc mạng, ví dụ, xác định các mục tiêu có thể: bộ định tuyến, máy chủ hoặc các thiết bị khác có thể chứa dữ liệu nhạy cảm. Có được thông tin này, kẻ tấn công dàn dựng cuộc tấn công của mình để có tác động tối đa.
- **ARP Spoofing:** Khi tìm thấy thiết bị mục tiêu, kẻ tấn công sẽ phát các phản hồi ARP giả mạo. Tin nhắn giả mạo này sẽ khiến thiết bị tin rằng địa chỉ MAC của kẻ tấn công là IP của máy chủ đáng tin cậy. Hành động đó khiến thiết bị nạn nhân cập nhật bộ đệm ARP của mình, và lưu lại rằng địa chỉ MAC của kẻ tấn công tương ứng với địa chỉ IP đáng tin cậy, do đó kẻ tấn công có thể giả mạo làm router đối với thiết bị mục tiêu.
- **Chặn lưu lượng:** Vì thiết bị mục tiêu làm mới bộ nhớ đệm ARP của nó bằng cách sử dụng địa chỉ MAC độc hại, nên tất cả lưu lượng truy cập đến máy chủ hợp lệ có thể bị kẻ tấn công chặn lại và điều này là minh bạch. Do đó, kẻ tấn công có thể chặn luồng thông tin đang truyền giữa các thiết bị được độc hoặc thậm chí can thiệp vào luồng thông tin đó mà không bị phát hiện ở cùng giai đoạn. Ở giai đoạn như vậy, tên người dùng, mật khẩu hoặc tin nhắn bí mật không mong muốn do đó có thể bị đánh cắp, gây ra rủi ro cho cả người đó và tổ chức.

- **Chuyển tiếp gói tin (tùy chọn):** Kẻ tấn công hiện có thể chọn chuyển tiếp lưu lượng bị chặn đến đích thực tế của nó. Điều này được sử dụng để duy trì giao diện hoạt động bình thường trong mạng, từ đó làm tăng độ khó phát hiện cuộc tấn công. Vậy nên, kẻ tấn công có thể thực hiện cuộc tấn công lâu hơn nữa bằng cách chuyển tiếp các gói tin để che giấu sự gián đoạn trong các dịch vụ. Cách này không chỉ giúp kẻ tấn công giữ an toàn cho bản thân mà còn tăng khả năng đánh cắp thông tin nhạy cảm hơn hoặc thậm chí là thao túng các thông tin liên lạc đang diễn ra tại thời điểm đó.



2.2. Các phương pháp phát hiện cuộc tấn công ARP-Poisoning

2.2.1. Dấu hiệu của một cuộc tấn công đang diễn ra

- Độ trễ mạng bất thường hoặc các vấn đề kết nối gián đoạn: Nếu kẻ tấn công đang thực hiện một cuộc tấn công MITM và không chuyển tiếp lưu lượng hiệu quả, nó có thể dẫn đến sự chậm trễ hoặc gián đoạn đáng chú ý trong giao tiếp mạng.
- Không thể truy cập một số trang web hoặc dịch vụ nhất định: Nếu kẻ tấn công nhắm mục tiêu vào cổng mặc định, nó có thể làm gián đoạn quyền truy cập internet của các thiết bị bị ảnh hưởng.

- Cảnh báo từ phần mềm bảo mật: IDS/IPS hoặc các giải pháp bảo mật điểm cuối có thể phát hiện và cảnh báo về hoạt động ARP đáng ngờ.
- Tìm thấy các địa chỉ MAC không mong muốn hoặc trùng lặp được liên kết với các địa chỉ IP quan trọng (như bộ định tuyến hoặc các máy chủ khác) là một chỉ số mạnh mẽ. .

2.2.2. Kỹ thuật phát hiện thụ động

- **Giám sát lưu lượng ARP:** Liên tục phân tích lưu lượng mạng để tìm các gói ARP có thể tiết lộ hoạt động đáng ngờ.
- **Tìm kiếm sự không nhất quán trong ánh xạ:** Phát hiện nhiều địa chỉ IP được liên kết với cùng một địa chỉ MAC trong các phản hồi ARP hoặc nhật ký giám sát mạng là một dấu hiệu của cuộc tấn công ARP-Poisoning. Điều này có thể được kiểm tra bằng cách xem xét bộ nhớ cache ARP của từng máy bằng lệnh arp -a.

Ví dụ: nếu địa chỉ IP của bộ định tuyến (ví dụ: 192.168.1.1) và một thiết bị khác trên mạng đều được ánh xạ đến địa chỉ MAC của kẻ tấn công, điều đó cho thấy sự "đầu độc".

- **Phát hiện các thông điệp ARP tự do (Gratuitous ARP):** Mặc dù các ARP tự do có mục đích sử dụng hợp pháp (ví dụ: để dự phòng), nhưng số lượng lớn các phản hồi ARP không mong muốn, đặc biệt là những phản hồi tuyên bố quyền sở hữu địa chỉ IP của bộ định tuyến từ một địa chỉ MAC không xác định, có thể đáng ngờ.
- **Sử dụng các công cụ chuyên dụng:** Các công cụ như arpwatich (trên Linux) có thể giám sát hoạt động mạng Ethernet và ghi lại các thay đổi trong ánh xạ địa chỉ IP và MAC. Các công cụ khác như XArp có thể cung cấp thông báo theo thời gian thực về các cuộc tấn công ARP.

=> Phát hiện thụ động dựa vào việc quan sát hành vi mạng và xác định các điểm bất thường trong các mẫu giao tiếp ARP. Dấu hiệu chính thường là sự hiện diện của các địa chỉ MAC trùng lặp được liên kết với các địa chỉ IP khác nhau. Bằng cách giám sát lưu lượng mạng, các hệ thống bảo mật có thể xác định các sai lệch so với hành vi ARP bình

thường mà không cần chủ động can thiệp vào mạng. Cách tiếp cận này có giá trị cho việc giám sát liên tục và phát hiện sớm.

2.2.3. Kỹ thuật phát hiện chủ động

- **Chèn các gói ARP giả mạo:** Các quản trị viên mạng có thể chủ động gửi các gói ARP thử nghiệm vào mạng để xác định các điểm yếu và xác minh tính toàn vẹn của các ánh xạ ARP.
- **Thực hiện các cuộc tấn công giả mạo (Ethical Hacking):** Mô phỏng các cuộc tấn công ARP-Poisoning trên mạng của chính bạn có thể giúp xác định các lỗ hổng trong hệ thống phòng thủ bảo mật và đánh giá hiệu quả của chúng.

=> Phát hiện chủ động liên quan đến việc chủ động thăm dò mạng để khám phá các lỗ hổng tiềm ẩn. Mặc dù xâm nhập hơn, nhưng nó cung cấp một đánh giá trực tiếp về khả năng phục hồi của mạng trước các cuộc tấn công ARP-Poisoning. Thay vì chỉ chờ đợi một cuộc tấn công xảy ra, các kỹ thuật chủ động cho phép quản trị viên kiểm tra hệ thống phòng thủ của họ và xác định các điểm yếu trước khi chúng có thể bị khai thác.

2.2.4. Sử dụng công cụ dòng lệnh và phần mềm giám sát mạng

- **Chạy lệnh: arp -a (Windows, macOS, Linux):** Hiển thị bảng bộ nhớ cache ARP, cho phép kiểm tra thủ công các địa chỉ MAC trùng lặp được liên kết với các địa chỉ IP khác nhau.
- **Wireshark:** Một trình phân tích giao thức mạng mạnh mẽ có thể thu thập và phân tích lưu lượng ARP, cho phép kiểm tra chi tiết các gói ARP và xác định các điểm bất thường. Các bộ lọc có thể được áp dụng trong Wireshark để cô lập các gói ARP.
- **Hệ thống Phát hiện/Ngăn chặn Xâm nhập (IDS/IPS):** Có thể được cấu hình để phát hiện các mẫu lưu lượng ARP đáng ngờ và có khả năng chặn các gói độc hại.

- **Hệ thống Quản lý Mạng (NMS):** Một số giải pháp NMS, như ManageEngine OpUtils, cung cấp các tính năng phát hiện ARP spoofing theo thời gian thực bằng cách giám sát bộ nhớ cache ARP của các thiết bị mạng.

=> Sự kết hợp giữa các công cụ tích hợp của hệ điều hành và phần mềm giám sát mạng chuyên dụng cung cấp các mức độ chi tiết và tự động hóa khác nhau để phát hiện ARP-Poisoning. Các công cụ dòng lệnh cung cấp các kiểm tra thủ công nhanh chóng, trong khi phần mềm chuyên dụng cung cấp khả năng giám sát liên tục và phân tích nâng cao. Các công cụ khác nhau phục vụ các nhu cầu và quy mô giám sát mạng khác nhau.

2.3. Cách bảo vệ hệ thống khỏi cuộc tấn công ARP-Poisoning

Sau đây là một số các biện pháp kiểm soát phòng ngừa và phát hiện

- **Bảng ánh xạ ARP tĩnh:** Bảng ánh xạ ARP tĩnh cho các thiết bị quan trọng ngăn chặn phản hồi ARP trái phép xâm nhập. Người quản trị đặt thủ công ánh xạ IP sang MAC. Do đó, chỉ những thiết bị đã biết và đáng tin cậy mới được nhận dạng trên mạng. Một nhược điểm lớn là quản lý cũng liên quan đến nó cũng như không khả thi với các mạng lớn.
- **Lọc gói tin:** Sử dụng công cụ packet filtering để lọc các gói ARP Spoofing, nếu phát hiện chúng chứa các thông tin nguy hiểm và tự động ngăn chặn khỏi các thiết bị mạng. Nguy cơ các gói tin giả mạo xâm nhập vào mạng được giảm đáng kể vì bất kỳ phản hồi ARP nào có thể có từ các thiết bị trái phép sẽ không đến được địa chỉ mong muốn.
- **Sử dụng Mạng riêng ảo (VPN):** Mã hóa thông tin liên lạc qua VPN có thể bảo vệ dữ liệu nhạy cảm, ngay cả khi bị chặn. Bằng cách sử dụng VPN, dữ liệu được đóng gói và mã hóa, khiến kẻ tấn công khó có thể giải mã bất kỳ lưu lượng nào bị chặn. Lớp bảo vệ này đảm bảo tính toàn vẹn của thông tin ngay cả khi ARP spoofing cho phép kẻ tấn công chặn lưu lượng, nhưng thông tin được bảo vệ khỏi truy cập trái phép.

2.4. Các loại tấn công ARP-Poisoning

Hiểu được loại tấn công giả mạo ARP hiện có là điều quan trọng đối với quản trị viên mạng và chuyên gia bảo mật vì nó cho phép họ bảo vệ mạng của mình hiệu quả trước các cuộc tấn công này. Bên cạnh cách tiếp cận chung, còn có các loại tấn công giả mạo khác nhau bao gồm:

- Giả mạo ARP cơ bản: Kẻ tấn công gửi các phản hồi ARP giả mạo đến một thiết bị và sau đó thiết bị đó liên kết địa chỉ MAC của kẻ tấn công với một IP hợp lệ (ví dụ, một cổng hoặc một thiết bị khác trên mạng). Sau đó, kẻ tấn công có thể chiếm đoạt lưu lượng truy cập đến IP đó và thậm chí thao túng dữ liệu mà nạn nhân không hề hay biết.
- Man-in-the-Middle (MitM) ARP Spoofing: Kẻ tấn công muốn chen vào giữa hai thiết bị giao tiếp bằng cách giả mạo phản hồi ARP để cả hai thiết bị đều nghĩ rằng chúng đang nói chuyện trực tiếp với thiết bị kia. Bằng cách này, kẻ tấn công có thể thay đổi nội dung giao tiếp, đánh cắp thông tin nhạy cảm hoặc chỉ chèn mã độc vào luồng lưu lượng.
- ARP Flooding (Từ chối dịch vụ): Kẻ tấn công làm ngập mạng bằng khối lượng lớn các phản hồi ARP giả, bằng mọi giá làm quá tải các bảng ARP của thiết bị. Kết quả là, các thiết bị không thể giao tiếp bình thường, trở thành nạn nhân của tình trạng DoS khi một số phần của mạng bị chết hoặc không khả dụng.
- Đầu độc bộ đệm ARP: Kẻ tấn công có thể gửi các phản hồi ARP giả mạo, không được yêu cầu để cập nhật bộ đệm của các thiết bị trong bảng ARP bị ghi đè bằng ánh xạ sai. Sau đó, kẻ tấn công có thể chuyển hướng lưu lượng đến chính mình hoặc một thiết bị độc hại để tạo điều kiện cho các cuộc tấn công xa hơn nữa, chẳng hạn như chặn dữ liệu, DoS hoặc thao túng mạng. Trong hầu hết các hệ thống, điều này sẽ tồn tại cho đến khi được xóa thủ công hoặc cho đến khi thiết bị được khởi động lại.

CHƯƠNG III: XÂY DỰNG CHƯƠNG TRÌNH PHÁT HIỆN ARP POISONING BẰNG PYTHON (SCAPY)

3.1. Giới thiệu về thư viện Scapy: Cách cài đặt và các chức năng liên quan đến ARP

Scapy là một thư viện mạnh mẽ và tương tác để thao tác gói tin, được viết bằng ngôn ngữ Python. Scapy có khả năng tạo (giả mạo) hoặc phân tích các gói tin thuộc nhiều giao thức khác nhau, gửi chúng qua mạng, bắt các gói tin, ghép nối các yêu cầu và phản hồi, và còn nhiều tính năng khác nữa.

Cách cài đặt Scapy: để cài đặt scapy, chạy lệnh sau trên terminal

pip install scapy

Một số thành phần chính của scapy

Class	Ý nghĩa
Ether()	Lớp gói tin Ethernet (Layer 2)
IP()	Gói tin IP (Layer 3)
TCP(), UDP(), ICMP()	Các gói tin tầng truyền tải (Layer 4)
ARP()	Gói tin ARP (địa chỉ ánh xạ)

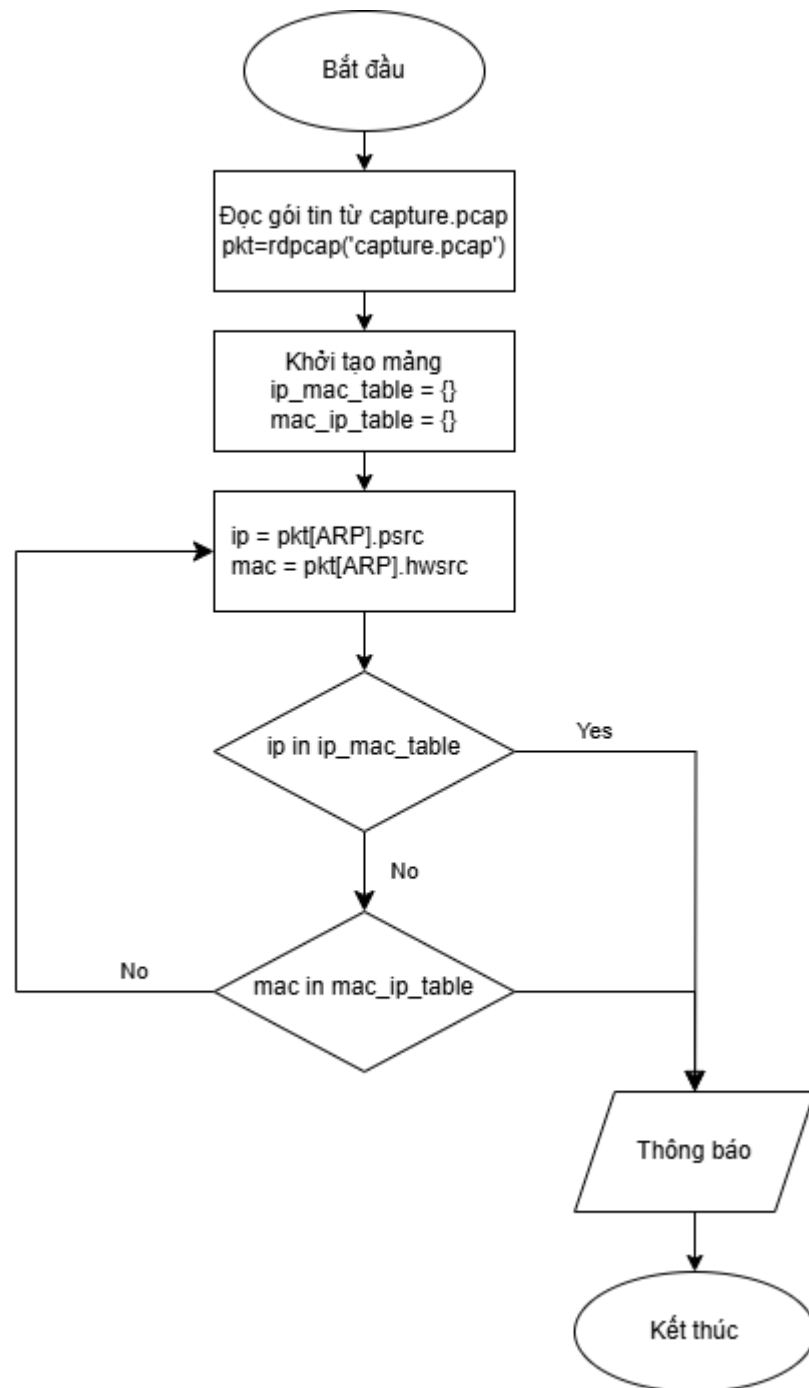
Hàm	Ý nghĩa
send()	Gửi gói tin ở Layer 3 (IP)
sendp()	Gửi gói tin ở Layer 2 (Ethernet)
sr()	Gửi và nhận phản hồi (send & receive)

sniff()	Bắt gói tin trên mạng
---------	-----------------------

3.2. Cấu trúc của chương trình

3.2.1. Ý tưởng

- Capture các gói ARP
- Phân tích gói ARP Reply
- Phát hiện khi 1 IP gắn với nhiều địa chỉ MAC khác nhau, hoặc nhiều địa chỉ IP gắn với cùng 1 địa chỉ MAC
- Thông báo khi phát hiện dấu hiệu tấn công



3.2.2. Cài đặt chương trình

Import thư viện

```
from scapy.all import rdpcap, ARP
```

Đọc tệp .pcap

```
packets = rdpcap('arp-poison.pcapng')
```

Khởi tạo bảng ánh xạ địa chỉ ip và địa chỉ mac

```
ip_mac_table = {}  
mac_ip_table = {}  
alerts = []
```

Thực hiện các logic, nếu 1 địa chỉ ip có nhiều mac, hoặc 1 địa chỉ mac gắn với nhiều địa chỉ ip thì thực hiện thông báo

```
for pkt in packets:  
    if ARP in pkt and pkt[ARP].op == 2:  
        ip = pkt[ARP].psrc  
        mac = pkt[ARP].hwsrc  
  
        if ip in ip_mac_table:  
            if ip_mac_table[ip] != mac:  
                alert = f"[ALERT] ARP Poisoning detected! IP {ip}  
was at {ip_mac_table[ip]}, now at {mac}"  
                print(alert)  
                alerts.append(alert)  
            elif mac in mac_ip_table:  
                if mac_ip_table[mac] != ip:  
                    alert = f"[ALERT] ARP Poisoning detected! MAC  
{mac} was at {mac_ip_table[mac]}, now at {ip}"  
                    print(alert)  
                    alerts.append(alert)  
                else:  
                    ip_mac_table[ip] = mac  
                    mac_ip_table[mac] = ip
```

3.3. Mô tả tệp mẫu arp-poisoning.pcap

Tệp arp-poisoning.pcap là một tệp dữ liệu được thu thập (capture) trong quá trình thực hiện một cuộc tấn công ARP Spoofing (còn gọi là ARP Poisoning) trong mạng LAN. Tệp này chứa các gói tin được ghi lại bằng công cụ như Wireshark hoặc tcpdump, và có thể được sử dụng để thử nghiệm chương trình phát hiện tấn công ARP.

arp-poison.pcapng 45.7 kb · 20 packets · [more info](#)

Start typing a Display Filter ✓ Apply Clear Filters ▾ Analysis Tools ▾ Graphs ▾ Export ▾ Profile

No.	Time	Source	Destination	Protocol	Length	Info
10	3.137851	Runtime_d9:0d:db	AmbitMic_aa:af:80	ARP	64	192.168.1.1 is at 00:20:78:d9:0d:db
16	7.142461	Runtime_d9:0d:db	AmbitMic_aa:af:80	ARP	64	192.168.1.1 is at 00:20:78:d9:0d:db
7	1.136550	AmbitMic_aa:af:80	AmbitMic_12:9b:01	ARP	64	192.168.1.1 is at 00:d0:59:aa:af:80 (duplicate use of 192.168.1.103 detected)
14	5.141324	AmbitMic_aa:af:80	AmbitMic_12:9b:01	ARP	64	192.168.1.1 is at 00:d0:59:aa:af:80 (duplicate use of 192.168.1.103 detected)
20	9.146104	AmbitMic_aa:af:80	AmbitMic_12:9b:01	ARP	64	192.168.1.1 is at 00:d0:59:aa:af:80 (duplicate use of 192.168.1.103 detected)
12	3.139347	AmbitMic_12:9b:01	AmbitMic_aa:af:80	ARP	64	192.168.1.103 is at 00:d0:59:12:9b:01 (duplicate use of 192.168.1.1 detected)
18	7.143913	AmbitMic_12:9b:01	AmbitMic_aa:af:80	ARP	64	192.168.1.103 is at 00:d0:59:12:9b:01 (duplicate use of 192.168.1.1 detected)
6	1.134550	AmbitMic_aa:af:80	Runtime_d9:0d:db	ARP	64	192.168.1.103 is at 00:d0:59:aa:af:80
13	5.139359	AmbitMic_aa:af:80	Runtime_d9:0d:db	ARP	64	192.168.1.103 is at 00:d0:59:aa:af:80
19	9.144139	AmbitMic_aa:af:80	Runtime_d9:0d:db	ARP	64	192.168.1.103 is at 00:d0:59:aa:af:80
2	0.000797	192.168.1.1	192.168.1.102	ICMP	64	Echo (ping) reply id=0xe77e, seq=256/1, ttl=150 (request in 1)
4	1.131382	192.168.1.1	192.168.1.103	ICMP	64	Echo (ping) reply id=0xe77e, seq=256/1, ttl=150 (request in 3)
8	1.235922	192.168.1.1	192.168.1.103	ICMP	64	Echo (ping) reply id=0xe77e, seq=256/1, ttl=150 (request in 5)
1	0.000000	192.168.1.102	192.168.1.1	ICMP	64	Echo (ping) request id=0xe77e, seq=256/1, ttl=125 (reply in 2)
3	1.130488	192.168.1.103	192.168.1.1	ICMP	64	Echo (ping) request id=0xe77e, seq=256/1, ttl=125 (reply in 4)
5	1.133280	192.168.1.1	192.168.1.103	ICMP	64	Echo (ping) request id=0xe77e, seq=256/1, ttl=125 (reply in 8)
11	3.138933	AmbitMic_aa:af:80	AmbitMic_12:9b:01	ARP	64	Who has 192.168.1.103? Tell 192.168.1.1 (duplicate use of 192.168.1.1 detected)

```

Frame 1: 64 bytes on wire (512 bits), 64 bytes captured (512 bits) on interface 0
Ethernet II, Src: AmbitMic_aa:af:80 (00:d0:59:aa:af:80), Dst: Runtime_d9:0d:db
  Destination: Runtime_d9:0d:db (00:20:78:d9:0d:db)
  Source: AmbitMic_aa:af:80 (00:d0:59:aa:af:80)
  Type: IPv4 (0x0800)
    Padding: 00000000000000000000000000000000
    Frame check sequence: 0x00000000 [unverified]
    [FCS Status: Unverified]
  Internet Protocol Version 4, Src: 192.168.1.102, Dst: 192.168.1.1
  Internet Control Message Protocol
  
```

0000 00 20 78 d9 0d db 00 d0 59 aa af 80 08 00 45 07 . x.....Y.....E.
0010 00 1c e7 7e 00 00 7d 01 d2 a3 c0 a8 01 66 c0 a8}......f..
0020 01 01 08 00 0f 81 e7 7e 01 00 00 00 00 00 00w.....
0030 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

3.4. Kết quả thu được khi chạy chương trình

Khi chạy thử nghiệm chương trình với tệp arp-poisoning.pcap trên, ta thu được kết quả như sau

```
[ALERT] ARP Poisoning detected! MAC 00:d0:59:aa:af:80 was at 192.168.1.103, now at 192.168.1.1
[ALERT] ARP Poisoning detected! IP 192.168.1.103 was at 00:d0:59:aa:af:80, now at 00:d0:59:12:9b:01
[ALERT] ARP Poisoning detected! IP 192.168.1.1 was at 00:20:78:d9:0d:db, now at 00:d0:59:aa:af:80
[ALERT] ARP Poisoning detected! IP 192.168.1.103 was at 00:d0:59:aa:af:80, now at 00:d0:59:12:9b:01
[ALERT] ARP Poisoning detected! IP 192.168.1.1 was at 00:20:78:d9:0d:db, now at 00:d0:59:aa:af:80
{'192.168.1.103': '00:d0:59:aa:af:80', '192.168.1.1': '00:20:78:d9:0d:db'}
{'00:d0:59:aa:af:80': '192.168.1.103', '00:20:78:d9:0d:db': '192.168.1.1'}
```

Chương trình đã phát hiện ra sự bất thường

- Địa chỉ MAC 00:d0:59:aa:af:80 ứng với 2 địa chỉ ip 192.168.1.103 và 192.168.1.1
- Địa chỉ IP 192.168.1.103 ứng với 2 địa chỉ MAC 00:d0:59:aa:af:80 và 00:d0:59:12:9b:01

Đánh giá hiệu quả chương trình phát hiện

Chương trình có khả năng phát hiện chính xác các hành vi thay đổi bất thường trong ánh xạ IP–MAC, vốn là dấu hiệu chính của tấn công ARP Poisoning. Khi sử dụng với tệp arp-poisoning.pcap, chương trình nhận diện đúng các tình huống IP được ánh xạ tới nhiều MAC khác nhau hoặc ngược lại.

Những hạn chế của phương pháp phát hiện chúng em nêu ra là

- Chưa giám sát theo thời gian thực được. Phải lưu các gói tin vào file pcap rồi mới phân tích được
- Không xác minh được thông tin MAC/IP nào là đúng. Chương trình chỉ phát hiện được các bất thường, chứ chưa xác định được đâu là kẻ tấn công, đâu là router, đâu là người bị tấn công

CHƯƠNG IV: HƯỚNG PHÁT TRIỂN

4.1. Tổng kết

ARP spoofing là một trong những mối đe dọa nghiêm trọng đối với bảo mật mạng chủ yếu vì nó can thiệp vào việc chặn thông tin, thao túng và làm gián đoạn lưu lượng dữ liệu giữa các thiết bị. Hiểu được cơ chế cho loại spoofing này, những rủi ro vốn có mà nó mang lại và các phương pháp được sử dụng để phát hiện và ngăn chặn nó sẽ tạo thành một số bước thiết yếu cho các tổ chức đang tìm cách bảo vệ mạng của họ khỏi các cuộc tấn công như vậy. Có nhiều phương pháp khác nhau có thể được sử dụng để phát hiện ARP spoofing, chẳng hạn như giám sát ARP, phân tích lưu lượng mạng và Hệ thống phát hiện xâm nhập (IDS). Các công cụ giám sát ARP sẽ phát hiện ra các bất thường, như nhiều địa chỉ MAC được liên kết với một IP duy nhất. Phân tích lưu lượng mạng xác định các mẫu bất thường có thể chỉ ra các nỗ lực giả mạo, và cảnh báo người quản trị về lưu lượng ARP đáng ngờ, cho phép phản hồi kịp thời các mối đe dọa tiềm ẩn. Bằng cách triển khai các biện pháp như sử dụng các bảng ánh xạ ARP tĩnh, công cụ packet filtering để lọc các gói ARP Spoofing hay sử dụng Mạng riêng ảo (VPN).

4.2. Hướng phát triển mở rộng

Chúng em đề xuất các hướng phát triển để mở rộng chương trình như sau

- Giám sát theo thời gian thực. Dùng `scapy.sniff()` để bắt trực tiếp các gói từ giao diện mạng
- Xác thực ARP: Kết hợp danh sách IP–MAC hợp lệ (whitelist) hoặc ARP tĩnh (`arp -s`) để đối chiếu. Từ đó tìm ra đâu là kẻ tấn công

CHƯƠNG V. PHÂN CÔNG NHÓM

Họ tên	Mã sinh viên	Phân công
Vũ Viết Duy	B21DCPT089	25%
Trần Tuấn Linh	B21DCPT145	25%
Trần Xuân Lâm	B21DCPT138	25%
Mai Thành Đạt	B21DCPT072	25%